Seguridad y antivirus

Carga de convenios

La carga sigue este orden: validación de extensión, MIME y tamaño; análisis mediante `FileScanner` y ClamAV TCP INSTREAM; movimiento del archivo limpio a `FCT_STORAGE_PATH`; y persistencia de metadatos. Los archivos permanecen fuera de `public/`. La descarga pasa por una ruta PHP con control de acceso.

En Docker, el punto de entrada comprueba al iniciar la aplicación que los directorios del volumen de almacenamiento sean propiedad de `www-data` y tengan permisos `0700`. Esto es necesario porque cambiar el propietario del directorio durante la construcción de la imagen no cambia el propietario de un volumen ya montado.

Cuando el análisis está habilitado, ClamAV no disponible, configuración inválida, timeout, firmas con más de tres días o respuesta `FOUND` hacen que la carga se rechace. No se debe convertir un error del antivirus en una carga aceptada.

Desarrollo local

El bypass es explícito y sólo se permite si ambas condiciones se cumplen:

```
APP_ENV=development
FCT_CLAMAV_ENABLED=false
```

En ese caso `FileScanner` registra una advertencia y omite el escaneo. El bypass sólo se acepta con `APP_ENV=development`, `APP_ENV=test` o `APP_ENV=testing`. No existe fallback automático ante un fallo de conexión. Compose usa `APP_ENV=production` y `FCT_CLAMAV_ENABLED=true` como valores de reserva, por lo que el análisis queda habilitado si no defines esas variables. Para probar la integración real, usa `FCT_CLAMAV_ENABLED=true` y espera a que `docker compose ps` muestre ClamAV saludable.

Si `APP_ENV` no es `development`, `test` o `testing`, el valor `false`, un valor inválido o la ausencia de un escáner funcional hacen que la carga se rechace. Mantén ClamAV habilitado en entornos compartidos y producción.

Usar ClamAV desde XAMPP

Al ejecutar PHP en XAMPP mientras ClamAV corre en Compose, configura el entorno del proceso PHP con `FCT_CLAMAV_ENABLED=true`, `FCT_CLAMD_HOST=127.0.0.1` y `FCT_CLAMD_PORT=3310`. El puerto de Compose está vinculado a `127.0.0.1`; el servicio `app` dentro de Docker se conecta directamente a `clamav:3310`.

Si se usa `clamscan` en vez de `clamd`, `FileScanner` admite `FCT_CLAMSCAN` como ruta absoluta al ejecutable y, opcionalmente, `FCT_CLAMAV_DATABASE` como ruta absoluta a la base de firmas. Define esas variables en el entorno que inicia Apache o el proceso CLI; crear un `.env` por sí solo no hace que PHP lo cargue. No publiques el puerto 3310 en interfaces de red compartidas ni públicas.

Otras protecciones

- Los archivos se guardan en almacenamiento privado separado del document root.
- Las mutaciones HTML requieren un campo CSRF `_csrf`; las acciones JSON del MVC usan `X-CSRF-Token`. La API tokenizada de `public/api.php` se autentica con un token Bearer.
- Los permisos se aplican por acción desde `routes/web.php`, antes de invocar el controlador.
- El rol Observador no puede ejecutar mutaciones de negocio ni descargar documentos privados.

Consulta Roles y permisos y el flujo de archivos.